

Burp Suite - Other Modules

Decoder: Overview

not only decodes data intercepted during an attack but also provides the function to encode our own data

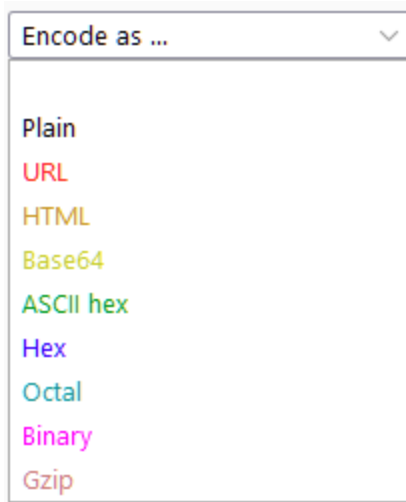
Decoder also allows us to create hashsums of data, as well as providing a Smart Decode feature, which attempts to decode provided data recursively until it is back to being plaintext (like the "Magic" function of [Cyberchef\(opens in new tab\)](#)).



1. This box serves as the workspace for entering or pasting data that requires encoding or decoding. Consistent with other modules of Burp Suite, data can be moved to this area from different parts of the framework via the **Send to Decoder** option upon right-clicking.
2. At the top of the list on the right, there's an option to treat the input as either text or hexadecimal byte values.
3. As we move down the list, dropdown menus are present to encode, decode, or hash the input.
4. The **Smart Decode** feature, located at the end, attempts to auto-decode the input.

Decoder: Encoding/Decoding

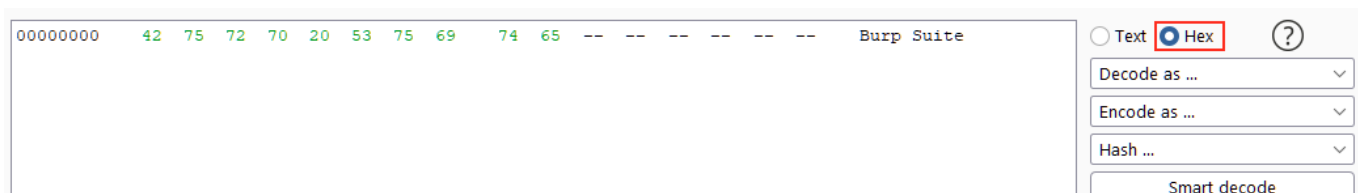
manual encoding and decoding options;



- **Plain:** This refers to the raw text before any transformations are applied.
- **URL:** URL encoding is utilized to ensure the safe transfer of data in the URL of a web request. It involves substituting characters for their ASCII character code in hexadecimal format
- **HTML:** HTML Entities encoding replaces special characters with an ampersand (&), followed by either a hexadecimal number or a reference to the character being escaped, and ending with a semicolon (;)
- **Base64:** Base64, a commonly used encoding method, converts any data into an ASCII-compatible format.
- **ASCII Hex:** This option transitions data between ASCII and hexadecimal representations. For instance, the word "ASCII" can be converted into the hexadecimal number "4153434949". Each character is converted from its numeric ASCII representation into hexadecimal.
- **Hex, Octal, and Binary:** These encoding methods apply solely to numeric inputs, converting between decimal, hexadecimal, octal (base eight), and binary representations.
- **Gzip:** Gzip compresses data, reducing file and page sizes before browser transmission. Faster load times are highly desirable for developers looking to enhance their SEO score and avoid user inconvenience.

Hex Format

While inputting data in ASCII format is beneficial, there are times when byte-by-byte input editing is necessary. This is where "Hex View" proves useful, selectable above the decoding options:



This feature enables us to view and alter our data in hexadecimal byte format, a vital tool when working with binary files or other non-ASCII data.

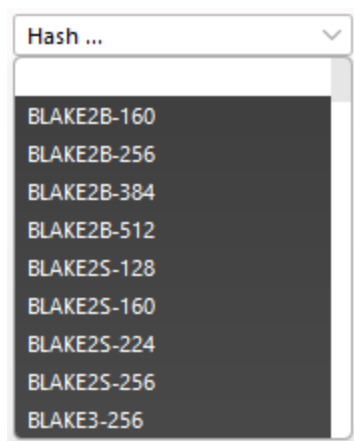
Smart Decode

This feature tries to auto-decode encoded text

Decoder: Hashing

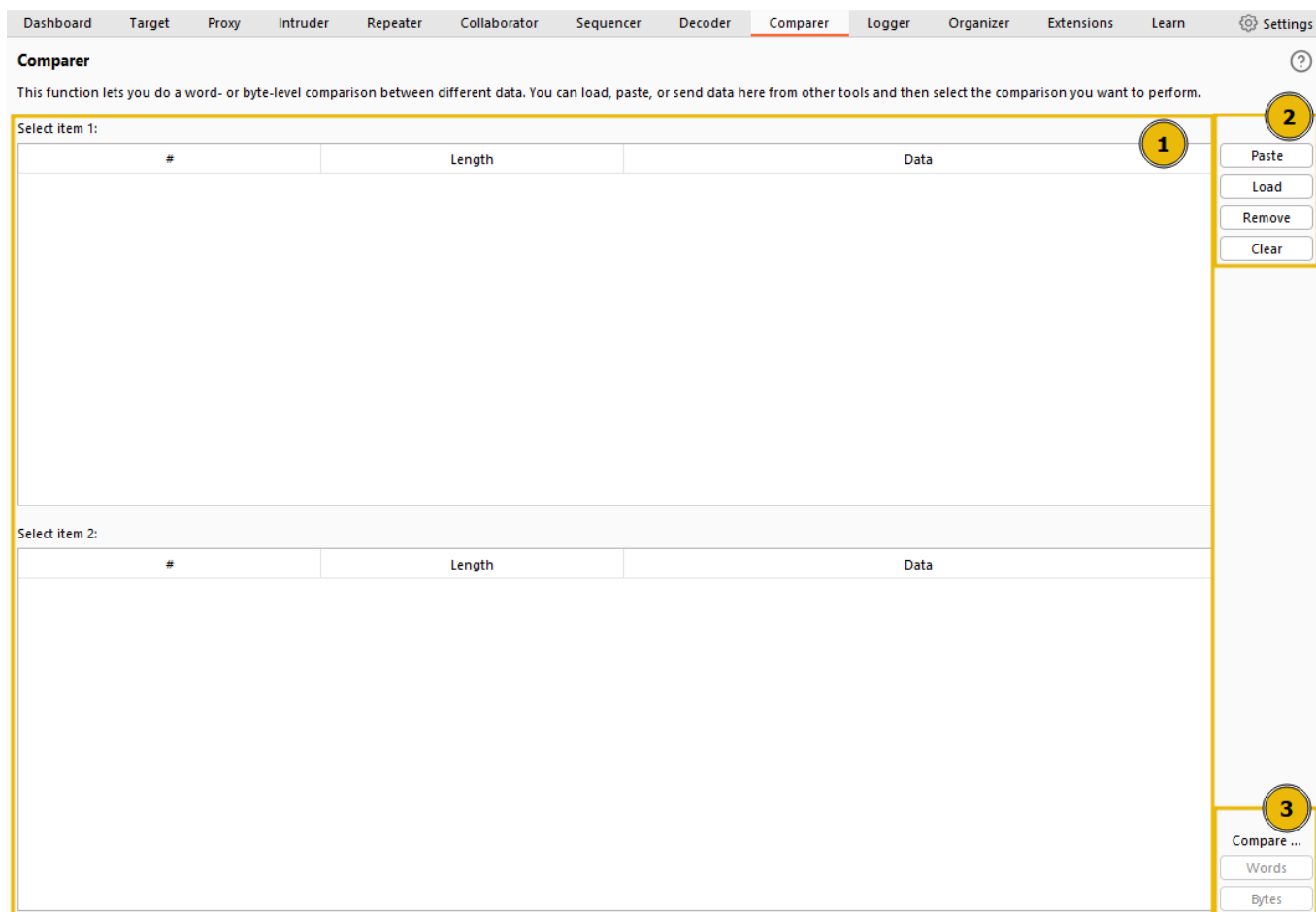
Hashing in Decoder

Decoder allows us to create hashsums for data directly within Burp Suite; it operates similarly to the encoding/decoding options we discussed earlier. Specifically, we click on the **Hash** dropdown menu and select an algorithm from the list:

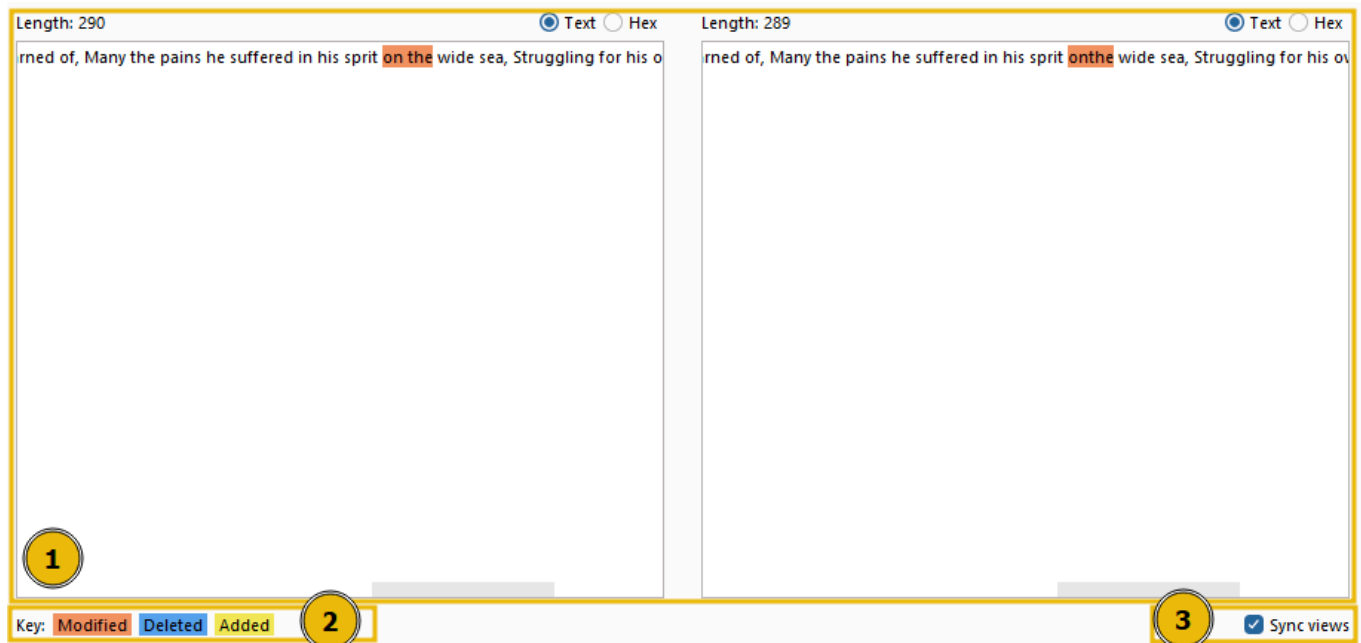


Comparer: Overview

lets us compare two pieces of data, either by ASCII words or by bytes.



1. On the left, we see the items to be compared. When we load data into Comparer, it appears as rows in these tables. We select two datasets to compare.
2. On the upper right, we have options for pasting data from the clipboard (Paste), loading data from a file (Load), removing the current row (Remove), and clearing all datasets (Clear).
3. Lastly, on the lower right, we can choose to compare our datasets by either words or bytes. It doesn't matter which of these buttons you select initially because this can be changed later. These are the buttons we click when we're ready to compare the selected data.



1. The compared data occupies most of the window; it can be viewed in either text or hex format. The initial format depends on whether we chose to compare by words or bytes in the previous window, but this can be overridden by using the buttons above the comparison boxes.
2. The comparison key is at the bottom left, showing which colours represent modified, deleted, and added data between the two datasets.
3. The **Sync views** checkbox is at the bottom right of the window. When selected, it ensures that both sets of data will sync formats. In other words, if you change one of them into Hex view, the other will adjust to match.

Comparer: Example

can capture requests with proxy send to the repeater then in the repeater click send to get a response then send the response to the comparer

i then did the same thing but with valid login credentials and can compare the 2 results

Comparer

This function lets you do a word- or byte-level comparison between different data. You can load, paste, or send data here from other tools and then select the comparison you want to perform.

Select item 1:

#	Length	Data
1	679	HTTP/1.1 302 FOUNDServer: nginx/1.18.0 (Ubuntu)Date: Wed, 08 Apr 2026 18:30:10 GMTContent-Type...
2	598	HTTP/1.1 302 FOUNDServer: nginx/1.18.0 (Ubuntu)Date: Wed, 08 Apr 2026 18:31:40 GMTContent-Type...

Select item 2:

#	Length	Data
1	679	HTTP/1.1 302 FOUNDServer: nginx/1.18.0 (Ubuntu)Date: Wed, 08 Apr 2026 18:30:10 GMTContent-Type...
2	598	HTTP/1.1 302 FOUNDServer: nginx/1.18.0 (Ubuntu)Date: Wed, 08 Apr 2026 18:31:40 GMTContent-Type...

the main thing i recognise is the successful attempts length was shorter than the one with the invalid credentials

Sequencer: Overview

Sequencer allows us to evaluate the entropy, or randomness, of "tokens".

These tokens could be session cookies or **Cross-Site Request Forgery (CSRF)** tokens used to protect form submissions. If these tokens aren't generated securely, then, in theory, we could predict upcoming token values. The implications could be substantial, for instance, if the token in question is used for password resets.

Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger

Live capture
Manual load
Sequencer settings

? **Select live capture request**

Send requests here from other tools to configure a live capture. Select the request to use, configure the other options below, then click "Start live capture".

Remove

Clear

#	Host	Request

Start live capture

? **Token location within response**

Select the location in the response where the token appears.

☐ Cookie:

☐ Form field:

☒ Custom location:

Configure

We have two main ways to perform token analysis with Sequencer:

- Live Capture:** This is the more common method and is the default sub-tab for Sequencer. Live capture lets us pass a request that will generate a token to Sequencer for analysis. For instance, we might want to pass a POST request to a login endpoint to Sequencer, knowing that the server will respond with a cookie. With the request passed in, we can instruct Sequencer to start a live capture. It will then automatically make the same request thousands of times, storing the generated token samples for analysis. After collecting enough samples, we stop the Sequencer and allow it to analyse the captured tokens.
- Manual Load:** This allows us to load a list of pre-generated token samples directly into Sequencer for analysis. Using Manual Load means we don't need to make thousands of requests to our target, which can be noisy and resource-intensive. However, it does require that we have a large list of pre-generated tokens.

Sequencer: Live Capture

capture request to loginpage then send the request to sequencer

The screenshot shows the 'Sequencer settings' window with two main sections:

Select live capture request
Send requests here from other tools to configure a live capture. Select the request to use, configure the other options below, then click "Start live capture".

#	Host	Request
1	http://10.129.156.69	POST /support/login/ HTTP/1.1Host: 10.129.156...
2	http://10.129.156.69	GET /admin/login/ HTTP/1.1Host: 10.129.156.69...

Below the table is a large empty box and a red button labeled "Start live capture".

Token location within response
Select the location in the response where the token appears.

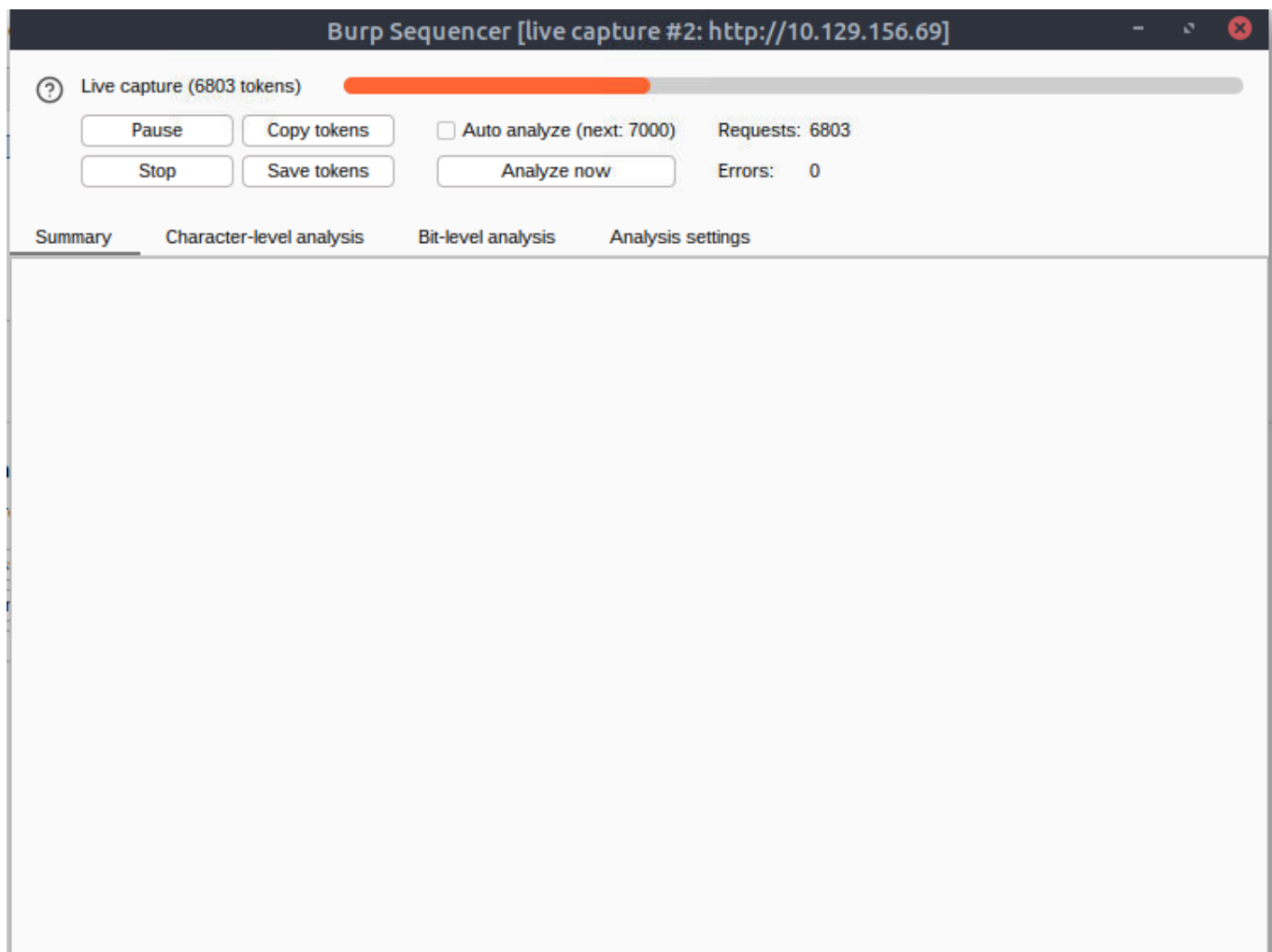
☒ Cookie: session=eyJ0b2t1bklEljoiNW...
☐ Form field: password=
☐ Custom location:
[Configure]

In the "Token Location Within Response" section, we can select between **Cookie**, **Form field**, and **Custom location**. Since we're testing the loginToken in this case, select the "Form field" radio button and choose the loginToken from the dropdown menu

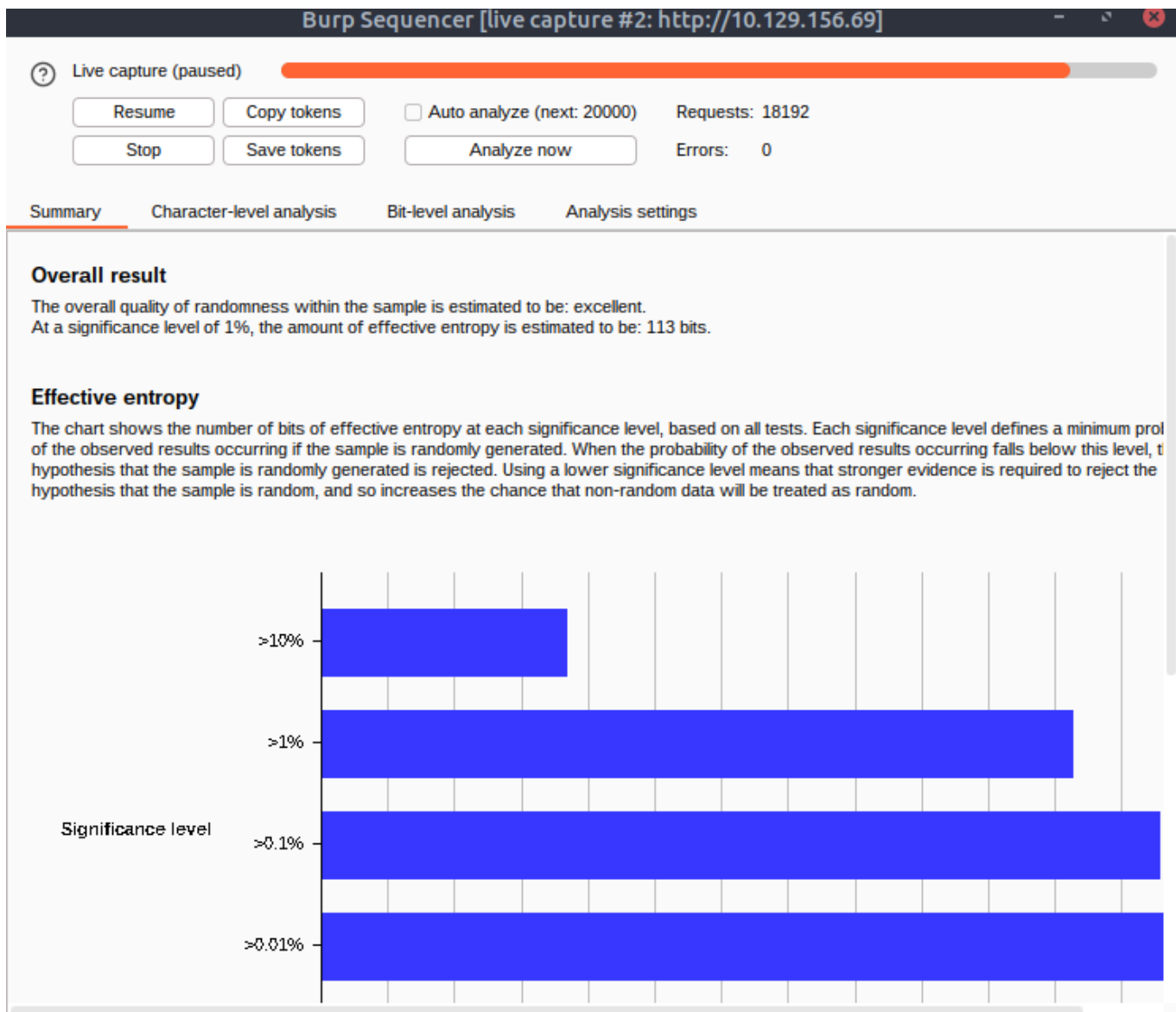
This screenshot shows the 'Token location within response' section with the 'Form field' radio button selected. The dropdown menu now shows 'loginToken=44cb4e7748866ee74935 ...'.

☐ Cookie: session=eyJ0b2t1bklEljoiNW...
☒ Form field: loginToken=44cb4e7748866ee74935 ...
☐ Custom location:
[Configure]

then can click on the live capture:



once per say 10000 tokens are captured I can use the analyse now feature which generates a report on the entropy/randomness



Sequencer: Analysis

- **Overall result:** This gives a broad assessment of the security of the token generation mechanism. In this case, the level of entropy indicates that the tokens are likely securely generated.
- **Effective entropy:** This measures the randomness of the tokens. The effective entropy of 117 bits is relatively high, indicating that the tokens are sufficiently random and, therefore, secure against prediction or brute force attacks.
- **Reliability:** The significance level of 1% implies that there is 99% confidence in the accuracy of the results. This level of confidence is quite high, providing assurance in the accuracy of the effective entropy estimation.
- **Sample:** This provides details about the token samples analysed during the entropy testing process, including the number of tokens and their characteristics.

summary report often provides enough information to assess the security of the token generation process, it's important to remember that further investigation may be necessary in

some cases. The character-level and bit-level analysis can provide more detailed insights into the randomness of the tokens

Organiser: Overview

The Organizer module of Burp Suite is designed to help you store and annotate copies of HTTP requests that you may want to revisit later. This tool can be particularly useful for organizing your penetration testing workflow. Here are some of its key features:

- You can store requests that you want to investigate later, save requests that you've already identified as interesting, or save requests that you want to add to a report later.
- You can send HTTP requests to Burp Organizer from other Burp Modules such as **Proxy** or **Repeater**. You can do this by right-clicking the request and selecting **Send to Organizer** or using the default hotkey `Ctrl + O`. Each HTTP request that you send to Organizer is a read-only copy of the original request saved at the point you sent it to Organizer.

The screenshot displays the Burp Suite interface with the **Proxy** tab selected. The **HTTP history** table lists several requests. A context menu is open for the first request (index 1), showing options like **Send to Organizer** (Ctrl+O). The **Request** pane shows the raw HTTP request details, and the **Inspector** pane shows the request headers and response headers.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Comment	TLS	IP
8	https://10-10-148-3.p.thml...	GET	/assets/js/scripts.js			200	601	script	js			✓	54.246.5.175
7	https://10-10-148-3.p.thml...	GET	/assets/js/bootstrap.bundle.min...			200	78727	script	js			✓	54.246.5.175
1	https://10-10-148-3.p.thml...	GET	/				6802	HTML		Bastion Hosting		✓	54.246.5.175

Request

```
1 GET / HTTP/1.1
2 Host: 10-10-148-3.p.thmlabs.com
3 Sec-Ch-Ua:
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: ""
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; AppleWebKit/537.36 (KHTML, like Gecko; Chrome/115.0.5790.102 Safari/537.36)
8 Accept: text/html,application/xhtml+xml,application/javascript;q=0.9,image/avif,image/webp,image/apng,*/*;application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: none
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
```

Inspector

Request attributes: 2

Request headers: 14

Response headers: 6

Requests are stored in a table, which contains columns such as the request index number, the time the request was made, workflow status, Burp tool that the request was sent from, HTTP method, server hostname, URL file path, URL query string, number of parameters in the request, HTTP status code of the response, length of the response in bytes, and any notes that you have made.

Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Learn
Settings

Filter: Showing all items
Pro version only

#	Time	Status	Tool	Method	Host	Path	Query	Param count	Status code	Length	Notes
1	18:26:03 27 Jul 2023	→ New	Proxy	GET	10-10-148-3.p.thmla...	/		0	200	6802	This is the home
2	18:26:04 27 Jul 2023	→ New	Proxy	GET	10-10-148-3.p.thmla...	/assets/js/scripts.js		0	200	601	This is the script,
3	18:33:19 27 Jul 2023	→ New	Repeater	GET	10-10-148-3.p.thmla...	/		0	200	6802	

Request
Pretty
Raw
Hex

1 GET / HTTP/1.1
2 Host: 10-10-148-3.p.thmlabs.com
3 Sec-Ch-Ua:
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: ""
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/115.0.5790.102 Safari/537.36
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q

0 matches

Response
Pretty
Raw
Hex
Render

1 HTTP/1.1 200 OK
2 Server: nginx/1.14.0 (Ubuntu)
3 Date: Thu, 27 Jul 2023 10:26:05 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Front-End-Https: on
7 Content-Length: 6613
8
9 <!DOCTYPE html>
10 <html lang=en>
11 <head>
12 <title>

0 matches

Notes
This is the homepage
Inspector
Notes

To view the request and response:

1. Click on any Organizer item.
2. The request and response are both read-only. You can search within the request or response, select the request, and then use the search bar below the request.

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearnSettings

Filter: Showing all itemsPro version only?

# ^	Time	Status	Tool	Method	Host	Path	Query	Param count	Status code	Length	Notes
1	18:26:03 27 Jul 2023	New	Proxy	GET	10-10-148-3.p.thmla...	/		0	200	6802	This is the homep
2	18:26:04 27 Jul 2023	New	Proxy	GET	10-10-148-3.p.thmla...	/assets/is/scripts.is		0	200	601	This is the scrip
3	18:33:19 27 Jul 2023	New	Repeater	GET	10-10-148-3.p.thmla...	/		0	200	6802	

Request

PrettyRawHex

8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

9 Sec-Fetch-Site: none

10 Sec-Fetch-Mode: navigate

11 Sec-Fetch-User: ?1

12 Sec-Fetch-Dest: document

13 Accept-Encoding: gzip, deflate

14 Accept-Language: en-US,en;q=0.9

15 Connection: close

16

0 matches

Response

PrettyRawHexRender

1 HTTP/1.1 200 OK

2 Server: nginx/1.14.0 (Ubuntu)

3 Date: Thu, 27 Jul 2023 10:33:20 GMT

4 Content-Type: text/html; charset=utf-8

5 Connection: close

6 Front-End-Https: on

7 Content-Length: 6613

8

9 <!DOCTYPE html>

10 <html lang=en>

11 <head>

12 <title>

0 matches

Notes

This is a test note

InspectorNotes